

SOP PROCEDURE

Manage IT System Lifecycle and Audit Readiness

Synthetic master SOP for pharma IT audit-readiness hackathon

Document ID	HACK-IT-SOP-001	Version	0.1
Status	Draft – Hackathon Test Artefact	Classification	Internal Use – Synthetic Content
Prepared for	Audit Readiness Hackathon	Prepared date	23 August 2026
Content Owner	Hackathon Organising Team [placeholder]	QA Reviewer	[To be assigned for simulation]
Effective date	Not applicable	Supersedes	None

CONTROLLED-STATUS WARNING

This document is deliberately synthetic and is not an approved or effective NN Quality Management System document. It must not replace current controlled QualityDocs, legal advice, validation plans or system-specific procedures. All names, evidence and test scenarios created for the hackathon must be fictional or properly sanitised. Verify every governing source at the point of use.

Contents

Section	Title
1	Purpose, scope and document status
2	Source hierarchy, applicability and normative language
3	Lifecycle and evidence-gate model
4	Governance, roles and responsibilities
5	General procedural requirements
6	Analyse phase
7	Implement phase
8	Operate phase
9	Retire phase
10	Cross-lifecycle control requirements
11	Hackathon audit-readiness test protocol
12	Deviations, exceptions and change to this test artefact
13	Records, retention and metrics
14	Worked examples
15	Difficult-auditor challenge pack
16	Confidence, limitations and known control gaps
17	References and source register
A	Appendix A – Phase deliverable and approval matrix
B	Appendix B – Revision and approval record

LIFECYCLE CONTROL IN ONE SENTENCE

A system may progress from Analyse to Implement to Operate to Retire only when accountable owners can produce current, approved and mutually consistent evidence that requirements, risks, configuration, verification, data, security, suppliers and operational controls meet predefined acceptance criteria.

1. This master procedure is an orchestration and audit-testing layer for the hackathon. Current effective NN instructions/procedures and applicable law always prevail.
2. Four macro phases contain 14 auditable lifecycle stages. Every stage defines entry criteria, mandatory activities, minimum evidence, approval/exit criteria, no-go conditions and difficult-auditor probes.
3. The governing approval matrix must be selected and documented before execution. Q0307516 is the IT-specific framework; Q218515 may govern generic equipment/mixed validation where its scope applies.
4. Audit readiness means demonstrable execution evidence—not document presence. The audit agent must identify contradictions, stale sources and missing evidence, state confidence and abstain when the corpus is insufficient.
5. Hackathon records must be synthetic, visibly segregated and non-production. No personal, confidential, patient, batch, clinical or live GxP records may be loaded into the test corpus without explicit authorisation and controls.

1 Purpose, scope and document status

1.1 Purpose

This procedure defines a single, phase-gated lifecycle for planning, acquiring, configuring/developing, verifying, releasing, operating, changing, recovering and retiring IT systems and digital solutions. It is designed to create a demanding but safe evidence corpus for testing an audit-readiness use case during a hackathon.

The procedure synthesises the supplied NN source corpus into a navigation layer. It does not create authority over a current controlled instruction, procedure, approved system-specific plan, applicable regulation or contractual obligation.

1.2 In scope

6. IT applications, configured SaaS/cloud services, custom solutions, integrations, data platforms, relevant infrastructure and digital solutions across their full lifecycle.
7. GxP and non-GxP systems, with the extent of rigour tailored through documented applicability and risk assessment.
8. Electronic records and signatures, data integrity, information security, privacy, supplier, interfaces, backup/recovery, records, training and inspection readiness.
9. Synthetic hackathon evidence packs and the AI-assisted retrieval/analysis workflow used to test audit readiness.

1.3 Out of scope and prohibited use

10. Approval or release of a live system, regulated process, production environment or real GxP record.
11. Substitution for current QualityDocs, system-specific validation/implementation plans, legal/privacy determinations, supplier contracts or authority commitments.
12. Use of copied NN content as proof of current effective status without a live controlled-source check.
13. Use of real patient, clinical, batch, employee, supplier-confidential or otherwise restricted data in an uncontrolled hackathon workspace.

1.4 Stakeholder lens and design challenge

Stakeholder	Primary need	Failure mode to challenge
QA / regulator	Traceable, independent, current and reproducible evidence; no unsupported conclusions	Excess formality can obscure the actual risk or create paper compliance
System/Process Owner	Clear accountability, residual-risk visibility and usable gates	A master SOP can duplicate or conflict with effective procedures
Engineering / delivery	Proportionate controls, reusable supplier evidence and automation	Rigid stage gates can penalise iterative delivery if baselines are misunderstood
Security / privacy / records	Complete component/data scope, enforceable controls and durable retention	Late involvement creates expensive redesign and hidden liabilities
Hackathon team	Realistic, explainable audit scenarios without operational risk	Synthetic evidence may be mistaken for real QMS records or reward confident guessing

Counterargument considered: a single master SOP may add no value where current procedures already govern.

Resolution: use this document only as a synthetic orchestration and test specification. It points to source requirements, makes conflicts explicit and defines the evidence needed to challenge an audit agent; it does not replace controlled process ownership.

1.5 Definitions

Term	Definition for this SOP
Critical Aspect (CA)	Requirement, function or parameter whose failure may affect product quality, patient safety or GxP data and therefore receives explicit risk, traceability and verification control.
Fit for intended use	Documented conclusion that the system performs the defined use reliably with applicable risks controlled and required evidence approved.
GxP	Applicable regulated good-practice requirements based on the supported process and records; applicability must be assessed, not assumed from the technology name.
ITRA	IT risk assessment in the designated risk-management workflow, including scope, controls, risk ownership and acceptance.
O&M	Operation and Maintenance description/instruction defining operational controls, frequencies, roles, evidence and escalation.
PSE	Periodic system evaluation that assesses lifecycle evidence and concludes whether the system remains valid/qualified and compliant.
True copy	Verified copy preserving the content, meaning and, where required, metadata, signatures, audit trail and contextual relationships of the original.
Validation evidence	Approved, attributable and retained records demonstrating that predefined acceptance criteria were met or deviations were controlled.

2 Source hierarchy, applicability and normative language

2.1 Source hierarchy

When requirements appear inconsistent, apply the following order and document the decision. Scope-specific effective instructions generally prevail over broader guidance; legal/regulatory applicability depends on the system and record context.

14. Applicable laws, regulations, marketing-authorisation commitments, authority commitments and binding contractual obligations.
15. Current effective NN QualityDocs instructions and procedures within their defined scope.
16. Current approved NN guidance, templates, checklists and user guides as implementation aids.
17. Approved system-specific risk assessments, plans, specifications, agreements, procedures and records consistent with higher sources.
18. This synthetic master SOP and other hackathon-only artefacts.

2.2 Mandatory point-of-use applicability check

19. Identify the system/process/record, jurisdiction, GxP context, component type and decision being made.
20. Open the controlled source; capture document ID, title, version, effective/status, scope and supersession relationship.
21. Resolve whether IT-system, infrastructure, computerised-equipment or mixed-system rules apply and cross-map role names.
22. Record conflicts, assumptions and selected governing clauses. Involve QA for GxP ambiguity before execution.
23. Link the source check to the lifecycle record and repeat when the decision, scope or controlled source changes.

2.3 Normative language

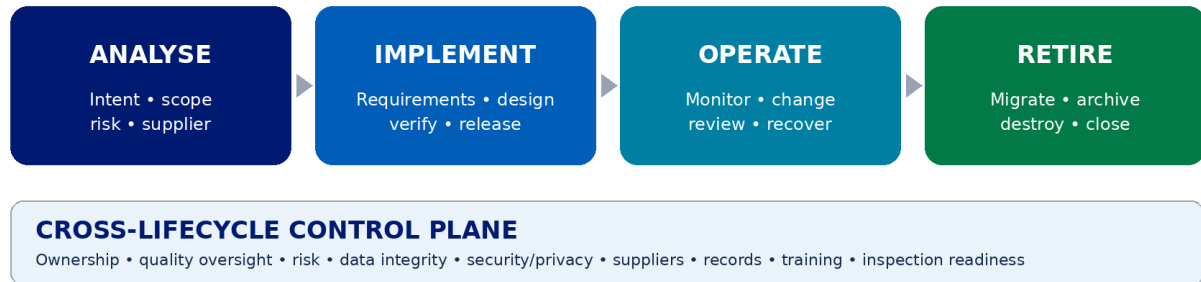
Term	Meaning
MUST	Mandatory within this synthetic SOP unless a higher governing source requires a different control. A deviation/exception cannot waive applicable law or a non-waivable controlled requirement.
SHOULD	Expected practice; a documented risk-based rationale and approved alternative are required when not followed.
MAY	Permitted option, subject to applicability, risk and approval.
Source caveat	A status seen in a supplied copy is evidence about that copy only. It is not proof of current effective status in live QualityDocs.

2.4 High-priority source conflicts resolved for this draft

Issue	Conflict / ambiguity	Applied rule in this synthetic SOP
Approval matrices	Q0307516 IT-specific versus Q218515 generic	Document system classification and governing matrix before execution; do not select retrospectively.
Role taxonomy	Owner/Manager/SME versus Operation/Engineering Responsible	Create a role-equivalence RACI; QA independence remains explicit.
Plan/URS timing	Current procedure versus older guidance	Approved final plan and URS before formal final design review; iterative informal reviews remain possible.
Test evidence	Legacy permission for 'OK' versus objective-evidence expectation	Use risk-scaled but reproducible actual evidence when it supports acceptance.
Failure handling	Defect versus validation deviation	Assess every failed formal criterion under current validation-deviation rules.
TRM coverage	Legacy 'one test per requirement' language	Trace every requirement to justified verification evidence, which may be test, review, analysis or qualified supplier evidence.
Handover	Unsigned checklist versus controlled release	Treat checklist as evidence index; require accountable operational acceptance and prior release.
Training copies	Q204010/Q0301870/Q216301 supplied status	Verify live effective state before governing use; retain the status caveat in all citations.
PSE timing	60-day expectation and informal extension wording	Use formal approved exception/deviation where late and assess validated-state impact.
Retirement timing	Final PSE/URR before retirement versus coverage through closure	Baseline review before execution plus final closeout through shutdown.

3 Lifecycle and evidence-gate model

Controlled lifecycle with evidence gates



Each gate requires approved evidence, traceability, explicit residual-risk decisions and controlled exceptions.

Figure 1. Phase progression is controlled by evidence gates; iteration is permitted when baselines and change history remain controlled.

3.1 Universal gate decision

24. Confirm entry criteria and current source applicability.
25. Complete risk-proportionate activities with trained, authorised and sufficiently independent roles.
26. Reconcile the complete evidence population: scope, requirements, risks, configuration, tests, deviations, changes and approvals.
27. Assess contradictions, open items and residual risk. Do not convert missing evidence into an assumption of compliance.
28. Record Gate outcome: GO, GO WITH CONTROLLED ACTIONS (not final release), RECYCLE/REWORK, or STOP.
29. Obtain required approvals before the next controlled activity; preserve exact version, signer, date/time and meaning.

3.2 Lifecycle stage overview

Macro phase	Stage	Required exit evidence	Primary no-go test
ANALYSE	Concept, intended use and business case	Approved concept package, appointed roles, system boundary/data flow, and initial applicability decision.	No solution selection or supplier access to regulated data when ownership, intended use, system boundary or mandatory applicability decisions are unresolved.
ANALYSE	User requirements specification (URS)	Approved, uniquely identified and baselined URS with classifications and traceability initiated.	No formal final design review or acceptance verification based on an unapproved, untraceable or non-verifiable URS.
ANALYSE	Risk assessment, criticality and software categorisation	Released ITRA/applicability assessment, functional risk assessment and justified validation/verification strategy.	No final validation strategy, design freeze or risk acceptance when material scope components, critical data flows, environments or supplier responsibilities are absent from the risk assessment.
ANALYSE	Supplier and service-provider assessment	Approved supplier assessment and agreement before delivery, regulated-data access or reliance on supplier evidence.	No supplier delivery, regulated-data access or validation-evidence reliance without an approved assessment, enforceable responsibility split and closed or accepted critical gaps.
IMPLEMENT	Functional and design specification	Approved design baseline and final design-review conclusion before acceptance verification.	No acceptance verification when the formal final design review is missing, based on draft inputs, omits Critical Aspects or lacks a clear fitness conclusion.
IMPLEMENT	Configuration, development and configuration management	Verified build/configuration, controlled code and artefacts, approved pre-verification baseline and complete configuration record.	No formal verification on an uncontrolled or unidentified build; no release where production configuration cannot be reconciled to an approved baseline.
IMPLEMENT	Installation verification / qualification	Approved IV/IQ report, reconciled component/configuration baseline and all material deviations closed.	No OQ/OV where the installed state, test environment, baseline, prerequisites or material deviations are unresolved.
IMPLEMENT	Operational verification / qualification	Approved OV/OQ report with objective evidence, traceability and closed material deviations.	No performance verification or release where Critical Aspect evidence is incomplete, failed criteria are unclassified, or material deviations remain open.
IMPLEMENT	Performance verification / qualification and user acceptance	Approved Pfv/PQ/UAT report, business acceptance and proven migration/cutover readiness where applicable.	No production release where intended-use workflows, critical outcomes, migration reconciliation, trained-user acceptance or material deviation closure are incomplete.
IMPLEMENT	Release, go-live and operational handover	Signed release, approved validation/implementation report, accepted O&M handover and communicated production status.	No production use before final release approval, validated-state/fitness conclusion, operational controls, training, authorised access and required backup/recovery readiness.
OPERATE	Operation, monitoring and periodic evaluation	Continuous operation with current evidence, timely reviews/actions and an explicit state-of-control conclusion.	Suspend or restrict affected use when evidence cannot support data integrity, security, recoverability, authorised access or continued validated/qualified state; assess product/data impact and escalation.

Macro phase	Stage	Required exit evidence	Primary no-go test
OPERATE	Change and configuration management	Implemented change linked to updated risk/specification/verification/configuration evidence and effectiveness conclusion.	No non-emergency implementation without approved impact/verification/rollback; no closure until actual state, documents, deviations and effectiveness are reconciled.
OPERATE	Incident, problem and validation-deviation management	Service restored safely, impact concluded, deviations/CAPA closed or controlled, recurrence risk reviewed and validated state addressed.	Do not resume affected regulated use or close the event when product/data impact, evidence preservation, risk, deviation or validated-state conclusions are unresolved.
RETIRE	Retirement, migration, archiving and destruction	System deactivated, data/records verified and retrievable, obligations transferred, access/interfaces removed and retirement report approved.	No deactivation, source deletion or destruction until approved retention/legal-hold decisions, verified transfer/retrieval, ownership transfer, interface/access closure and fallback criteria are met.

4 Governance, roles and responsibilities

Role titles can vary, but responsibilities and approval meaning must remain unambiguous. One individual may hold multiple delivery roles when competent and permitted; QA approval/release independence must not be collapsed into delivery accountability.

Activity	System Owner	System Manager	Process / Operation	QA	Data / Technical SMEs	Supplier / Sourcing
Intended use / system boundary	A	R	C	C	C	C
Criticality and residual-risk acceptance	A*	R	C	C	C	C
GxP scope / QA involvement	C	R	C	A	C	C
URS	A	R	C	A†	C	C
Supplier assessment/agreement	A	R	C	A†	C	R/C
Implementation/validation plan	A	R	C	A†	C	C
Design and final design review	C	A/R	C	A†	C	C
Configuration/development	C	A	I	C	R	R/C
IV/OV verification	C	A	C	C/A†	R	R/C
PfV/PQ/UAT	C	A/R	A/R	A†	R	C
Migration / data disposition	C	R	C	A†	R/C	C
Release / validated-state conclusion	A	R	C	A†	C	C
Production access review	A	R	C	C	R/C	C
Changes	A/C	R	C	A/C†	R	C
Incidents/problems/deviations	A/C	R	C	A/C†	R	R/C
PSE / continued validated state	A	R	C	A†	C	C
Retirement plan/report	A	R	C	A†	R/C	C

Legend: A = accountable/approves; R = responsible; C = consulted; I = informed. * Non-delegable Owner decision. † QA approval only where required by GxP/applicable governing source. Project-specific RACI and controlled approval matrix prevail.

4.1 Core role duties

Role	Minimum responsibility
System Owner	Accountable for lifecycle compliance, intended-use fitness, resources, system criticality, non-delegable residual-risk acceptance, required approvals, training and retirement obligations.
System Manager	Plans and executes supplier/design/development/verification/operation/change/incident/recovery/retirement activities; maintains system record and evidence index.
Business Process Owner / Operation Responsible	Owns process needs, intended use, business controls, representative acceptance, continuity and impact decisions.
Data Owner / DRP	Classifies data, defines complete record/retention, approves migration/archive where required, and owns retrieval/access/quality decisions.
QA	Provides independent GxP applicability, risk, document, deviation, release and periodic-state oversight/approval as required; challenges source and evidence quality.
Technical/Engineering SMEs	Design, configure, verify, operate and review components using controlled methods; provide evidence and independent technical review.
Information Security / Privacy / Records	Confirm control, exception, legal/retention and data-protection requirements within their authority.
Supplier / Sourcing	Execute assessed and contracted responsibilities; provide controlled evidence, notifications, performance, CAPA and exit support. NN accountability remains internal.

5 General procedural requirements

30. Maintain one authoritative system ID and reconcile it across ITOM/asset, risk, supplier, validation, access, change, incident, backup, periodic-review and retirement records.
31. Use science- and risk-based tailoring. Increased uncertainty, complexity or importance requires increased formality; resource pressure is not a rationale for weaker risk management.
32. Plan lifecycle activities before execution. Define scope, roles, source hierarchy, dependencies, baselines, deliverables, evidence, approvals, tools, deviation/change methods, migration, rollback, training and retention.
33. Maintain bidirectional traceability throughout the lifecycle. Every applicable requirement must point to risk/control, design and justified verification evidence; every test/design item must point back to an authorised source.
34. Predefine objective acceptance criteria. Actual results, failures, deviations, criteria changes, retest/regression and conclusions must remain attributable and reconstructable.
35. Use supplier evidence only after documented suitability and integrity assessment. NN remains responsible for intended-use fitness and inspection access.
36. Control configuration and records across all environments. Establish baselines before formal verification and before release, and link every later difference to authorised change.
37. Escalate unresolved product/patient/data-integrity, security/privacy, recovery, legal-hold or source-currency uncertainty. An audit agent must report 'not demonstrated' when the evidence does not support a conclusion.

5.1 Evidence acceptance test

Test	Minimum question
Identity	System/component/environment/version/date and record ID are unambiguous.
Authority	Author/reviewer/approver are competent, authorised and sufficiently independent; signature meaning is clear.
Currency	Controlled status/effective version and supersession were verified at point of use.
Completeness	Population, attachments, raw/native data, metadata, audit trail and linked deviations/changes are reconciled.
Traceability	Assertion links to requirement/risk/design/execution/approval without unexplained gaps.
Integrity	Evidence is attributable, contemporaneous, protected from inappropriate alteration and retained in usable context.
Consistency	Dates, versions, roles, results and scope agree across independent records; contradictions are resolved, not ignored.
Conclusion	Predefined criteria are compared with actual results and residual risk; limitations/open items are explicit.

6 Analyse phase

Define intent, ownership, requirements, risk and supplier controls before solution commitments create hidden scope or compliance debt.

6.1 Concept, intended use and business case

Objective	Entry criteria	Gate / approval	Exit criteria
Establish why the system is needed, what process and data it supports, where its boundaries lie, and which lifecycle controls apply before a solution is selected.	Documented business need or replacement trigger; sponsor identified.	System Owner accountable; Business Process Owner concurs with intended use; QA confirms GxP applicability where relevant.	Approved concept package, appointed roles, system boundary/data flow, and initial applicability decision.

Mandatory activities

38. Define the intended use, supported business process, user population, sites, environments, interfaces, records, data flows and exclusions in plain language.
39. Appoint a named NN System Owner with mandate and resources and a System Manager before regulated or business-critical decisions are made. Record any delegation or role equivalence; the Owner retains accountability.
40. Identify the Business Process Owner/Operation Responsible, Data Owner or Data Responsible Person, QA contact, security/privacy contacts, technical SMEs and supplier-management contacts as applicable.
41. Classify business criticality and screen for GxP, electronic records/signatures, personal data, information-security, retention, continuity, financial and regulatory-reporting relevance.
42. Define the system-of-record boundary, upstream/downstream dependencies, infrastructure/platform dependencies and whether AI/ML functionality is present.
43. Confirm the live QMS source hierarchy and currency before relying on a copied or SharePoint-hosted procedure; record the check in the source register.
44. Document assumptions, constraints, alternatives, expected benefits and a preliminary exit/retirement concept so lock-in and data-retention risks are visible at selection time.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Concept/intended-use statement	Unique system ID; process, users, sites, functionality, data, interfaces, exclusions and success criteria	System Owner
Role appointment and RACI	Named individuals, mandate, delegation/equivalence and independence constraints	System Owner / management
Scope and data-flow view	Physical/logical boundary, environments, data categories, sources, destinations and ownership	System Manager + Data Owner
Initial applicability record	GxP/Part 11/privacy/security/retention/BCP/AI decisions with rationale and source versions	Owner; QA where GxP
Decision log/business case	Alternatives, assumptions, value, constraints, lifecycle cost and exit risks	Sponsor / Owner

Difficult-auditor probes

45. Show how the system boundary in the concept matches the component and interface inventory used later in risk assessment and testing.
46. Which decision is non-delegable, and where is the System Owner's personal acceptance recorded rather than merely routed through a workflow proxy?
47. What controlled source proves that the supplied copy was current on the date the applicability decision was made?

NO-GO CONDITION

No solution selection or supplier access to regulated data when ownership, intended use, system boundary or mandatory applicability decisions are unresolved.

Internal and external basis: Q187219 §§1–4; Q187218; Q0307516; EU GMP Annex 11 Principle and §§1–2; ICH Q9(R1) §§3–4.2.

6.2 User requirements specification (URS)

Objective	Entry criteria	Gate / approval	Exit criteria
-----------	----------------	-----------------	---------------

Objective	Entry criteria	Gate / approval	Exit criteria
Translate intended use, process needs and risk controls into complete, unambiguous, objectively verifiable lifecycle requirements.	Approved intended use, defined scope/data flow and identified stakeholders.	System/Project Owner and QA for GxP under the IT-specific framework; approved final URS before formal final design review.	Approved, uniquely identified and baselined URS with classifications and traceability initiated.

Mandatory activities

48. State functional, data, interface, performance, availability, usability, support, security, privacy, data-integrity, audit-trail, electronic-signature, backup/recovery, retention and reporting requirements as applicable.
49. Give every requirement a unique ID, source, rationale, owner, objective acceptance criterion and applicability/criticality classification.
50. Identify Critical Aspects whose failure may affect product quality, patient safety or GxP data; link them to documented risk assessment.
51. Ensure requirements are correct, complete, consistent, feasible, necessary and verifiable. Avoid subjective terms unless quantified or operationally defined.
52. Address unused standard functionality, configuration options, manual workarounds, exceptional paths, data limits, error handling and required segregation of duties.
53. Retain obsolete or superseded requirements with status and rationale; do not delete history. Establish the traceability matrix when the URS is created.
54. A supplier may draft requirements, but NN retains ownership, review, approval and the duty to resolve conflicts with internal process and regulatory needs.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Approved URS	Unique IDs, revision history, intended-use link, measurable acceptance criteria and signatures	Owner + QA where applicable
Requirement quality review	Completeness/consistency/feasibility/verifiability review; unresolved comments controlled	Peer/SMEs
Critical-aspect classification	Product/patient/data impact rationale and functional-risk links	Process SME + QA
Initial traceability matrix	URS-to-risk and planned design/verification links; no unexplained orphan	System Manager

Difficult-auditor probes

55. Select one high-risk workflow and show the exact URS ID, risk, design element, test evidence and operational control without relying on document titles alone.
56. Which requirements were removed or weakened during supplier selection, who approved the decision, and how is the previous text retained?
57. How was standard but unused SaaS functionality assessed for security, data-integrity or inadvertent activation risk?

NO-GO CONDITION

No formal final design review or acceptance verification based on an unapproved, untraceable or non-verifiable URS.

Internal and external basis: Q187219 §4.4; Q0307516; Q0355466; EU GMP Annex 11 §4.4; Annex 15 §§3.1–3.3.

6.3 Risk assessment, criticality and software categorisation

Objective	Entry criteria	Gate / approval	Exit criteria
Determine the level of lifecycle rigour and the controls needed to reduce product, patient, data, business, security and privacy risks to an explicitly accepted level.	Intended use, scope, data flow and draft requirements available.	System Owner accepts criticality and residual risk; this acceptance is not delegated. QA reviews/approves GxP scope and risks as required.	Released ITRA/applicability assessment, functional risk assessment and justified validation/verification strategy.

Mandatory activities

58. Complete the applicable IT risk assessment workflow and document any permitted exemption with contemporaneous criteria and approval; workflow ability to skip QA is not proof that QA is unnecessary.
59. Assess product quality, patient safety, GxP data, data integrity, information security, privacy, records/retention, continuity, supplier, interface, migration and operational risks.

60. For GxP functionality, perform a functional risk assessment that maps hazards, causes, consequences, existing controls, residual risk and Critical Aspects to requirements and verification.
61. Categorise software/components based on actual configuration or customisation and complexity. Use category to scale evidence, never to waive intended-use fitness or risk controls.
62. Define risk scales and acceptance criteria before scoring. Make uncertainty, evidence quality, assumptions and subjectivity visible; avoid arithmetic scores that conceal high severity.
63. Record control owners, due dates, implementation evidence and verification method. Reassess risk after control implementation and at relevant changes, incidents, supplier events and periodic review.
64. Document the system-specific approval framework: IT system, infrastructure, computerised equipment or mixed system, including cross-mapping of Owner/Manager and Operation/Engineering roles.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
ITRA/applicability assessment	Released scope, components/environments, controls, risk owners, Owner acceptance and QA decision	Owner + QA as applicable
Functional risk assessment	Hazard-to-requirement/Critical Aspect links, defined scales, control verification and residual risk	Owner/process SME + QA
Software/component categorisation	Inventory-level category and rationale tied to actual configuration/custom code	System Manager
Risk-action register	Owner, due date, objective evidence, status, overdue escalation and retest/reassessment	Control owners
Approval-framework decision	Scope rule, role mapping and selected approval matrix with live-source citation	Owner + QA

Difficult-auditor probes

65. Show a control marked implemented in the risk tool and the independent execution evidence proving it is effective in production.
66. Why did the selected approval matrix differ from the generic validation framework, and where was the lex-specialis decision approved?
67. Which high-severity scenarios remained numerically 'medium' and how were they prevented from being masked by detectability or probability scoring?

NO-GO CONDITION

No final validation strategy, design freeze or risk acceptance when material scope components, critical data flows, environments or supplier responsibilities are absent from the risk assessment.

Internal and external basis: Q187219 §§1–2 and Appendix 1; Q187218; Q0307516; Q218515; Q187655; ICH Q9(R1) §§3–5.3; EU GMP Annex 11 §1.

6.4 Supplier and service-provider assessment

Objective	Entry criteria	Gate / approval	Exit criteria
Demonstrate that suppliers, services and subcontractors are competent, controlled and contractually able to support the intended regulated use throughout the lifecycle.	Defined requirements, risk classification and sourcing strategy.	System Owner/Manager, Sourcing and QA as applicable; Owner approves evaluation-method rationale and residual risk; agreements follow procurement/legal authority.	Approved supplier assessment and agreement before delivery, regulated-data access or reliance on supplier evidence.

Mandatory activities

68. Assess supplier quality system, relevant regulatory experience, information security, data integrity, privacy, financial/technical viability, development/support practices and use of subcontractors.
69. Determine and justify audit, visit, SOC/independent-report or alternative evaluation method and frequency. A certificate alone is not an assessment.
70. For SOC reliance, reconcile report scope, type, period, opinion, exceptions, subservice carve-outs, complementary user-entity controls and the gap to the NN service/configuration.
71. Execute agreements before delivery and define QMS interfaces, responsibilities, service levels, inspector access, audit rights, evidence retention/access, environments, hosting/data locations, changes, incidents, subprocessors and exit/transition support.
72. Define supplier notification and customer acceptance controls for SaaS/cloud releases, configuration changes, security events, GxP data changes and backend maintenance.
73. Establish SMART KPIs including quality, data integrity, security/privacy incidents, availability, recovery and CAPA. Review supplier performance and the need for re-evaluation at least annually as required by the source framework.

74. Plan supplier phase-out: data and asset return, knowledge transfer, access removal, evidence retention, licence termination, legal review and unresolved-obligation closure.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Supplier assessment	Scope, method/frequency rationale, risk, findings/CAPA, approval and current status	Owner/Manager + QA/Sourcing
Audit/SOC evaluation	Period/scope mapping, exceptions, CUECs, subservices, gap actions and conclusion	Qualified reviewer
Executed agreements	Quality/security/privacy/SLA/shared-responsibility/inspection/retention/exit clauses	Authorised signatories
KPI and re-evaluation record	Trend, breaches, CAPA, annual method decision and continued-use conclusion	Owner/Manager + QA
Supplier evidence suitability	Raw-data availability, environment/version, tester competence/independence, deviations and integrity checks	System Manager + QA

Difficult-auditor probes

75. Prove that no supplier work, environment access or regulated-data processing occurred before the required assessment and agreement approvals.
76. Which SOC complementary user controls apply to this tenant, who owns them, and what execution evidence proves each was effective during the report-gap period?
77. How does the contract preserve inspection-ready evidence and usable data after supplier termination or platform obsolescence?

NO-GO CONDITION

No supplier delivery, regulated-data access or validation-evidence reliance without an approved assessment, enforceable responsibility split and closed or accepted critical gaps.

Internal and external basis: Q187219 §4.1; Q0807260; Q0744001; Q0781393; EU GMP Annex 11 §§3.1–3.4; 21 CFR 11.10(k).

7 Implement phase

Translate approved requirements and risks into controlled design, build, verification, release and operational readiness evidence.

7.1 Functional and design specification

Objective	Entry criteria	Gate / approval	Exit criteria
Demonstrate how approved requirements and risk controls are implemented in an architecture and design fit for intended use.	Approved plan/strategy, URS, risk assessment and selected supplier solution.	As defined in the approved plan; formal final design review by System/Project Manager and QA for applicable GxP IT systems.	Approved design baseline and final design-review conclusion before acceptance verification.

Mandatory activities

78. Describe architecture, components, interfaces, data flows, environments, prerequisites, security zones and physical/logical arrangements at a level commensurate with risk and complexity.
79. For configured functionality, document how each relevant URS is realised, including environment-specific values. For custom code, define modules, logic, data structures, interfaces, error handling and critical parameters.
80. Embed least privilege, segregation of duties, audit trails, electronic signatures, data retention, backup/recovery, availability, monitoring, privacy and secure-interface controls in the design.
81. Uniquely identify design elements and maintain bidirectional traceability from risk/URS to design/configuration and planned verification evidence.
82. Perform iterative peer reviews and a formal final design review. The final review must use approved final URS/plan/design, cover all Critical Aspects and use a justified sampling method for noncritical populations.
83. Record findings, severity, owner, due date, evidence and closure. Open follow-ups must be closed before the gate or explicitly controlled with assessed impact in the implementation plan/report.
84. Conclude explicitly whether the design is fit for intended use, compliant with applicable GMP requirements and reduces Critical Aspect risk to an acceptable level.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Functional/configuration/design specifications	Unique IDs/versions, architecture/data flows, control details and traceability	Authors + planned approvers
Design-risk review	Failure/control analysis including security, DI, interfaces, migration and recoverability	Cross-functional SMEs
Final design-review report	Population/sample rationale, all Critical Aspects, findings/closure and unambiguous fitness conclusion	Manager + QA
Updated traceability matrix	URS-to-design/configuration coverage; explained gaps/orphans	System Manager

Difficult-auditor probes

85. Reconcile the design-review sample to the complete design population and prove every Critical Aspect was included rather than inferred from spot checks.
86. Show how a privileged direct-database action is prevented, detected and reviewed when the normal application audit-trail assessment excludes it.
87. Which design assumption changed after review, and how were risk, requirements, tests and approvals updated without breaking the baseline?

NO-GO CONDITION

No acceptance verification when the formal final design review is missing, based on draft inputs, omits Critical Aspects or lacks a clear fitness conclusion.

Internal and external basis: Q187219 §§4.5–4.6; Q0307516; Q0723392; Q0749711; EU GMP Annex 11 §§4.3–4.7; Annex 15 §3.3.

7.2 Configuration, development and configuration management

Objective	Entry criteria	Gate / approval	Exit criteria
Build or configure the system in a controlled manner and preserve a reproducible, approved configuration baseline.	Approved design baseline, development/CM strategy and controlled environments/tools.	Approvers and independence defined in the plan; independent review for development verification; baseline acceptance assigned in RACI.	Verified build/configuration, controlled code and artefacts, approved pre-verification baseline and complete configuration record.

Mandatory activities

88. Use a controlled development/configuration process with authorised repositories, version history, reviewed standards, defined branching/build/release controls and segregated environments.
89. Identify configuration items, attributes, versions, relationships and owners across application, infrastructure, interfaces, scripts, reports, security roles, pipelines and operational dependencies.
90. Perform risk-based code/configuration review. High-risk and Critical Aspect-supporting code must be independently reviewed unless an exceptional, documented risk justification is approved in the plan.
91. Verify development against design and preserve objective results. If development evidence will be reused as validation evidence, predefine suitability and data-integrity checks.
92. Establish an approved baseline before first formal verification and another final baseline after the last change before release. Reconcile actual versus recorded configuration.
93. Control additions, modifications and removals through change/configuration processes and maintain status accounting, history and configuration-audit evidence.
94. Hackathon strengthening for custom/cloud solutions: maintain dependency/SBOM inventory, secrets and vulnerability scanning, build provenance, signed artefact/checksum where feasible, and qualified/assessed CI/CD controls. These are risk-based additions, not asserted as explicit requirements of every supplied NN procedure.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
CM plan and CI register	Scope, roles, attributes, tools, relationships, lifecycle states and change links	Assigned CM owner
Repository/build history	Source/version, reviewed changes, build inputs/output and reproducibility metadata	Development lead
Code/configuration review	Reviewer independence, standards, findings, closure and design trace	Independent reviewer
Configuration baselines	Approved pre-test and pre-release versions with environment comparison/diff	System Manager
Supply-chain security evidence	Dependencies, scan results, exceptions, provenance and deployment-gate decision	Security/technical SMEs

Difficult-auditor probes

95. Rebuild the released artefact from retained source and dependencies, or explain the controlled alternative proving exact provenance.
96. Compare the production configuration to the approved baseline and explain every difference, including emergency and supplier-made changes.
97. Who approved the CM scope and baseline when the legacy guidance names no mandatory approver? Show the project-specific RACI that closes the gap.

NO-GO CONDITION

No formal verification on an uncontrolled or unidentified build; no release where production configuration cannot be reconciled to an approved baseline.

Internal and external basis: Q187219 §§4.6–4.7; Q0307516; Q0356054; Q0723392; Q0750180; 21 CFR 11.10(k); EU GMP Annex 11 §10.

7.3 Installation verification / qualification

Objective	Entry criteria	Gate / approval	Exit criteria
Verify that the correct components are installed and configured in the intended environment against predefined criteria.	Approved installation/IV plan, controlled baseline, qualified/assessed environment and trained executors.	IT-specific IV plan/report: System/Project Manager; apply the documented alternative matrix if the scope is equipment/infrastructure or mixed.	Approved IV/IQ report, reconciled component/configuration baseline and all material deviations closed.

Mandatory activities

98. Define environment prerequisites, installation sequence, versions, configuration parameters, accounts, dependencies, calibration/measurement needs, data and rollback before execution.
99. Verify installed components, software, infrastructure, interfaces, certificates, scheduled jobs, monitoring agents, security configuration and required supplier documentation against specifications.
100. Record actual results, evidence references, executor identity/date and environment context for each step. A bare tick or 'OK' is insufficient where objective evidence is the acceptance basis.

101. Assess automated deployment and verification tools for adequacy and control; retain logs sufficient to reconstruct what was deployed where, when and by whom.
102. Use 'verify once/deploy many' only with a documented equivalence rationale covering image/artefact identity, environment differences, transport and installation effects.
103. Classify every failed acceptance or expected result under the current validation-deviation process, with impact, correction, retest/regression and closure.
104. Reconcile the as-installed inventory to the approved baseline and update configuration records before progressing.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Approved IV/IQ protocol	Scope, prerequisites, steps, criteria, evidence expectations and traceability	Manager / matrix approvers
Executed IV/IQ record	Actual results, native logs/screenshots, who/when/where and deviation links	Executor + reviewer
As-installed inventory/configuration diff	Component/version/parameter reconciliation and approved exceptions	Technical SME / CM owner
IV/IQ report	Criteria comparison, deviations, configuration-control and phase conclusion	Manager / matrix approvers

Difficult-auditor probes

105. Prove that the evidence corresponds to the tested environment and exact build, not a supplier demo or a different tenant.
106. What prevents an automated deployment log from being altered or detached from the release record after execution?
107. For verify-once/deploy-many, identify every environment-specific variable and the evidence that it cannot invalidate the reused result.

NO-GO CONDITION

No OQ/OV where the installed state, test environment, baseline, prerequisites or material deviations are unresolved.

Internal and external basis: Q187219 §§4.7–4.8; Q0307516; Q0697805; Q0779271; Annex 15 §§3.8–3.9; EU GMP Annex 11 §4.7.

7.4 Operational verification / qualification

Objective	Entry criteria	Gate / approval	Exit criteria
Demonstrate that the system operates as designed across intended ranges, limits, error paths and risk controls.	Successful IV/IQ, approved OV/OQ plan/scripts, controlled baseline/environment/data and trained roles.	IT-specific OV plan/report: System/Project Manager; alternative two-approver framework applies only when documented as governing.	Approved OV/OQ report with objective evidence, traceability and closed material deviations.

Mandatory activities

108. Approve plans, scripts and acceptance criteria before execution. Define prerequisites, data, accounts, tools, environment, dependencies, evidence standards and deviation handling.
109. Use risk-based scenarios covering normal, boundary, negative, invalid-input, error-handling, state-transition, concurrency, performance/load and recovery conditions as applicable.
110. Verify Critical Aspect functions and controls for access, segregation, audit trails, electronic signatures, data accuracy, interfaces, reports, calculations, backup/recovery, security and retention.
111. Record expected and actual results at step level, including input/context, tester/date, native output or reproducible evidence, and independent review. Do not substitute pass/fail labels for the evidence necessary to support the conclusion.
112. Evaluate automated test tools and test environments for adequacy; place GxP-critical tools under change/configuration control and preserve tool/version/run metadata.
113. For supplier FAT/SAT or development evidence, document suitability, controlled acquisition, transport/installation impact, data integrity, environment/version equivalence and any supplemental tests.
114. Record every failed formal acceptance result and classify it under the validation-deviation procedure; predefine retest and regression based on impact, not convenience.
115. A scientifically erroneous acceptance criterion may only change through a controlled deviation/change with QA agreement and a new or appropriately reapproved protocol; never edit the criterion merely to fit the result.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Approved OV/OQ plan and scripts	Risk/URS trace, predefined criteria, prerequisites, data and evidence expectations	Manager / governing matrix
Executed test evidence	Actual values, native logs/screenshots, tester/date/context and independent review	Tester + reviewer
Supplier-evidence suitability	Scope/version/environment, integrity, competence, deviations and supplemental coverage	System Manager + QA
Validation-deviation records	Classification, root cause/impact, correction/CAPA, retest/regression and closure	Manager; QA per class
OV/OQ report	Criteria comparison, failures/deviations, traceability, configuration and clear outcome	Governing approvers

Difficult-auditor probes

116. Show a negative or boundary test whose failure could corrupt data, and the native evidence that the rejection and audit-trail behaviour were correct.
117. Identify any criterion changed after first execution; reconstruct the timestamped approval, scientific rationale, original failure and new protocol.
118. Demonstrate that attachments and automated results in the test-management tool are complete, immutable enough for their use and retained in native context.

NO-GO CONDITION

No performance verification or release where Critical Aspect evidence is incomplete, failed criteria are unclassified, or material deviations remain open.

Internal and external basis: Q187219 §4.8; Q0307516; Q0697805; Q0779271; Q0300381; Annex 15 §§2.4–2.10 and 3.10–3.12; EU GMP Annex 11 §4.7.

7.5 Performance verification / qualification and user acceptance

Objective	Entry criteria	Gate / approval	Exit criteria
Confirm fitness for intended use in representative end-to-end business workflows with competent users and realistic operating conditions.	Successful IV/OV, stable baseline, approved PfV/PQ/UAT plan, trained users and representative controlled data.	System/Project Manager and QA when Critical Aspects are affected under the IT matrix; follow the documented governing framework.	Approved PfV/PQ/UAT report, business acceptance and proven migration/cutover readiness where applicable.

Mandatory activities

119. Execute end-to-end workflows that represent intended use, roles, sites, interfaces, data volumes, operating ranges, exceptional paths and critical business deadlines.
120. Use representative, versioned and privacy-compliant test data. Document provenance, masking/synthesis, representativeness, reuse, reconciliation and prevention of production contamination.
121. Ensure users are trained and authorised for their test roles; capture actual results and objective evidence with the same discipline as other formal verification.
122. Verify critical process outcomes, reports, decisions, calculations, approvals, signatures and handoffs—not only screen behaviour.
123. For migration, approve a plan and report that proves completeness and accuracy, preservation of meaning, metadata, audit trails, signatures and required dynamic functionality, with reconciled populations and exceptions.
124. Test cutover sequence, rollback/fallback, interface synchronisation and operational monitoring where migration or major deployment creates continuity risk.
125. User acceptance does not replace risk-based IV/OV, design verification, supplier suitability or QA release requirements.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Approved PfV/PQ/UAT plan	Representative workflows/data/users, criteria, traceability and cutover/migration scope	Manager + QA per matrix
Executed end-to-end evidence	Business outcome, actual results, roles/dates, native artefacts and exceptions	Trained users + reviewer
Test-data record	Source/masking/synthesis/version/representativeness/reconciliation/disposal	Data Owner / test lead
Migration/cutover report	Record counts/control totals, exceptions, metadata/AT/signature checks, rollback and conclusion	Data Owner + QA

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
PfV/PQ/UAT report	Criteria comparison, deviations, fitness and explicit user/process acceptance	Governing approvers

Difficult-auditor probes

126. Trace a randomly selected migrated record from source through transformation to target, including metadata, audit trail, signature context and control totals.
127. How was test-data representativeness justified without copying personal or GxP production data into an uncontrolled environment?
128. Show an exceptional workflow or rollback test, not merely the happy-path transaction used for user sign-off.

NO-GO CONDITION

No production release where intended-use workflows, critical outcomes, migration reconciliation, trained-user acceptance or material deviation closure are incomplete.

Internal and external basis: Q187219 §4.8; Q0307516; Q218515; Q0715589; Q204010; Annex 15 §§3.13–3.14; EU GMP Annex 11 §§4.8 and 5.

7.6 Release, go-live and operational handover

Objective	Entry criteria	Gate / approval	Exit criteria
Authorise production use only when lifecycle evidence proves fitness, operational control and inspection readiness.	Successful acceptance verification, final baseline, completed traceability and release package.	System/Project Manager and QA for applicable release; System Owner concludes fitness and approves validation report; QA grants final GxP release.	Signed release, approved validation/implementation report, accepted O&M handover and communicated production status.

Mandatory activities

129. Prepare a current system description covering physical/logical arrangements, components, data flows, interfaces, prerequisites, security, environments and documentation inventory.
130. Complete bidirectional traceability from every applicable requirement and Critical Aspect to approved design and justified verification evidence; investigate all unexplained gaps and orphans.
131. Close all validation deviations and related changes required for final release. Assess and record unresolved non-deviation issues with owner, due date, residual risk and release impact.
132. Approve the implementation/validation report against the plan, including changes to strategy, supplier-evidence reuse, results, deviations, configuration control, residual risk and a clear validated/fit conclusion.
133. Approve O&M before operations; include support, monitoring, access, security, incidents, changes, backup/recovery, audit-trail review, supplier, continuity, records, training and periodic review responsibilities.
134. Confirm trained support/users, authorised access, backup execution and restore readiness, monitoring/alerts, service records, licences, inspection binder and communication of release.
135. Use the handover checklist as an evidence index only. Require accountable outgoing/incoming acceptance, action-plan risk assessment, hypercare criteria and proof that QA release precedes production use.
136. Conditional approval may exceptionally permit progression to another verification stage after documented no-significant-impact assessment; it must never be used as a production go-live waiver.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Release decision	Exact version/environment, criteria, open-item assessment, Owner fitness and QA release timestamp	Manager + QA / Owner
Implementation/validation report	Plan comparison, results, deviations, configuration, residual risk and validated-state conclusion	Owner + QA
System description/document index	Current architecture, data flows/interfaces, prerequisites and approved evidence locations	System Manager
Approved O&M and recovery plan	Named roles, frequencies, thresholds, escalation, evidence retention and test status	Peer/QA per scope
Handover acceptance	Outgoing/incoming accountability, open actions, knowledge transfer, secrets/access, hypercare and exit	Owner/Manager + operations

Difficult-auditor probes

137. Compare production's first transaction timestamp with QA release, baseline approval, access approval and backup activation; explain any out-of-sequence event.

138. Reconcile the handover checklist to the release decision and prove that missing rows or deleted template sections did not conceal a no-go item.
139. Which unresolved issue was accepted at go-live, by whom, using what risk evidence, and where is its closure/effectiveness proof?

NO-GO CONDITION

No production use before final release approval, validated-state/fitness conclusion, operational controls, training, authorised access and required backup/recovery readiness.

Internal and external basis: Q187219 §4.8 and Appendix 1; Q0307516; Q0359333; Q0359339; EU GMP Annex 11 §§4, 7, 12 and 16; Annex 15 §2.10.

8 Operate phase

Maintain control through monitored operation, periodic evaluation, authorised change and disciplined incident/deviation handling.

8.1 Operation, monitoring and periodic evaluation

Objective	Entry criteria	Gate / approval	Exit criteria
Maintain the system in a controlled, secure, recoverable and validated/qualified state through evidence-based operation and review.	Approved release, O&M, operational ownership, monitoring and support model.	System Owner accountable; System Manager executes; QA reviews/approves GxP O&M and applicable PSE/validated-state conclusions.	Continuous operation with current evidence, timely reviews/actions and an explicit state-of-control conclusion.

Mandatory activities

140. Operate under current approved O&M instructions and maintain the system record, component/interface inventory, data-flow view, contacts, supplier responsibilities and inspection evidence index.
141. Monitor availability, jobs, interfaces, capacity, security events, data-integrity controls, backup completion, recovery readiness, supplier KPIs and control exceptions at defined frequencies and thresholds.
142. Authorise, implement, revoke and review access across production and relevant platforms. Review production access at least annually and include privileged, service/machine, database, OS, local and non-central accounts plus segregation conflicts.
143. Maintain a risk-based audit-trail assessment and controlled local review instruction for GxP data. Cover creation/change/deletion and explicitly close the admin/direct-DB logging handoff through IRM controls.
144. Perform GxP periodic system evaluation at the applicable risk-defined frequency, at least once every three years under the cited guidance; if no frequency assessment exists, use the stated yearly default. Do not treat an informal extension as closure.
145. Review risk assessments, supplier evaluation need, security controls and documentation when triggered and at their defined maximum intervals. Track actions and overdue items through formal escalation/deviation as appropriate.
146. Trend changes, incidents, problems, deviations, access, performance, vulnerabilities, supplier events and backup/recovery results; conclude whether the validated/qualified state and regulatory compliance remain acceptable.
147. Retain native, attributable, legible, contemporaneous, original/true-copy, accurate, complete, consistent, enduring and available evidence for the required retention period.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Current O&M/system record	Named roles, frequencies, thresholds, procedures, components/interfaces and evidence links	System Manager; QA as applicable
Monitoring/control evidence	Timestamped outputs, review, exceptions, tickets/CAPA and trend conclusions	Control owners
User review report	Complete account population, authorisation reconciliation, rejected privileged activity and timely closure	Owner/Manager
ATR assessment and reviews	Scope/rationale/frequency, instruction, independent review outcomes and issue links	Owner + QA
PSE/periodic evaluation	Defined period, all required domains, actions and explicit validated/qualified-state conclusion	Owner + QA

Difficult-auditor probes

148. Reconcile the authorised-user source to live application, platform, database and privileged-account populations; explain every unmatched identity.

149. Show the last complete audit-trail review and prove its population excludes neither admin actions nor direct data manipulation without an effective compensating control.
150. Select one missed backup or supplier KPI breach and trace detection, impact, escalation, correction, trend and periodic-review conclusion.

NO-GO CONDITION

Suspend or restrict affected use when evidence cannot support data integrity, security, recoverability, authorised access or continued validated/qualified state; assess product/data impact and escalation.

Internal and external basis: Q187219 §4.9; Q0359339; Q204010/Q0301870 status caveat; Q0355420; Q0361022; EU GMP Annex 11 §§5–12 and 16; 21 CFR 11.10(b)–(k).

8.2 Change and configuration management

Objective	Entry criteria	Gate / approval	Exit criteria
Ensure planned, emergency and supplier-initiated changes are assessed, authorised, verified and effective without loss of control or validated state.	Released system under approved O&M/change procedure and current baseline.	Change Manager/System Manager, System Owner, QA and business/technical roles according to impact and governing QMS workflow.	Implemented change linked to updated risk/specification/verification/configuration evidence and effectiveness conclusion.

Mandatory activities

151. Record every GxP IT change in the IT service/change system and cross-reference the required QMS change record when product, process, validated state, GxP data, regulatory documentation or Critical Aspects may be affected.
152. Classify scope, reason, urgency and impact before implementation. Assess data, interfaces, suppliers, security/privacy, infrastructure, records, training, business continuity, rollback and cumulative effects.
153. Update risk assessment, requirements, design, traceability, tests, O&M, recovery, supplier agreements and system records where impacted; preserve history.
154. Define implementation sequence, prerequisites, deployment evidence, verification/regression, acceptance criteria, rollback/fallback, communications and segregation of duties.
155. Authorise the plan before implementation except under a controlled emergency route. Emergency changes require documented necessity, minimum prior risk/approval, retrospective evidence and timely formal closure.
156. For SaaS/vendor push releases, maintain advance notification, release-note triage, tenant-impact assessment, non-production evidence or justified alternative, production monitoring and acceptance/rejection/escalation.
157. After implementation, reconcile the actual configuration to the approved change and baseline, close deviations, verify effectiveness and conclude continued validated/qualified state.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Linked IT/QMS change records	Reason/scope/impact, cross-reference or justified no-QMS decision, approvals and timestamps	Change Manager + QA as applicable
Risk and traceability update	Affected requirements/controls/tests/docs/interfaces/data and residual risk	System Manager/SMEs
Implementation/rollback plan	Sequence, roles, evidence, communications and objectively testable criteria	Technical lead + approvers
Executed verification	Exact version/environment, results, deviations, regression and baseline diff	Tester/reviewer
Closure/effectiveness record	Outcome, open items, monitoring and validated/qualified-state conclusion	Owner/Manager + QA

Difficult-auditor probes

158. Find one production configuration difference with no change ID and reconstruct who made it, why, its impact and how completeness was assessed.
159. For the last supplier push release, show the evidence bridge from release notes to risk triage, verification, production monitoring and final acceptance.
160. Why was a QMS change not created for a validated-system change, and which controlled applicability rule supports that decision?

NO-GO CONDITION

No non-emergency implementation without approved impact/verification/rollback; no closure until actual state, documents, deviations and effectiveness are reconciled.

Internal and external basis: Q0364761 status caveat; Q216301 status caveat; Q0307516; EU GMP Annex 11 §10; Annex 15 §§11.1–11.7; 21 CFR 11.10(k).

8.3 Incident, problem and validation-deviation management

Objective	Entry criteria	Gate / approval	Exit criteria
Contain failures, preserve evidence, assess product/data impact, restore controlled service and prevent recurrence.	Detected failure, alarm, user report, test exception, security/privacy event or control breach.	Incident/problem roles and System Manager; QA for GxP assessment and validation-deviation closure per classification; accountable Owner accepts residual risk.	Service restored safely, impact concluded, deviations/CAPA closed or controlled, recurrence risk reviewed and validated state addressed.

Mandatory activities

161. Log all incidents promptly with time, reporter/detector, affected system/version/data/process, symptoms, impact, evidence, priority and related change/deviation/security/privacy records.
162. Prioritise using current factual impact and urgency, and escalate potential Major/Critical events immediately. Automated security or data-integrity alarms must not be delayed merely because the initial channel was not telephone escalation.
163. Preserve relevant logs, audit trails, records and forensic evidence; restrict access and avoid actions that destroy causality or original data.
164. Assess patient/product/GxP data impact, data integrity, security, privacy breach, regulatory reporting, other records/batches/systems, validated state and need for recovery/BCP.
165. Verify workarounds and fixes before use. A workaround may restore service but does not by itself close root cause, data impact, deviation/CAPA or validated-state obligations.
166. Classify every formal verification failure and significant protocol departure as a validation deviation. When in doubt between major/minor, use the more conservative class until justified.
167. Investigate Critical/Major events and recurring or systemic lower-priority trends through problem/CAPA management. Define root cause, contributing factors, corrective/preventive actions, effectiveness checks and cross-system extent.
168. Before closure, reconcile affected data, changes, tests, configuration, open risks and communications; update periodic review and inspection evidence.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Incident record	Complete chronology, impact/priority, evidence, decisions, resolution and user acceptance	Incident roles
GxP/DI/security/privacy assessment	Scope/population, rationale, escalation/reporting and validated-state conclusion	SMEs + QA
Problem/RCA/CAPA	Root/contributing causes, extent, actions, owners/dates and effectiveness	Problem owner + QA as applicable
Validation deviation	Class, impact, correction/CAPA, retest/regression, change links and closure approvals	Manager; QA per class
Trend review	Aggregate incidents, thresholds, recurring patterns and problem/CAPA trigger decisions	System Manager / Owner

Difficult-auditor probes

169. Select a severe incident closed on a workaround and prove the separate root-cause, data-impact, deviation, residual-risk and CAPA records reached defensible conclusions.
170. Show how recurring High/Medium incidents are aggregated and which objective threshold triggers formal problem management.
171. Trace a failed test step initially labelled a defect and prove it was also assessed under the validation-deviation procedure before release.

NO-GO CONDITION

Do not resume affected regulated use or close the event when product/data impact, evidence preservation, risk, deviation or validated-state conclusions are unresolved.

Internal and external basis: Q187219 §4.10; Q0928895; Q0690200; Q0300381; EU GMP Annex 11 §13; 21 CFR 211.192.

9 Retire phase

Transfer or dispose of systems, data and records while preserving retrieval, integrity, ownership and legal/regulatory obligations.

9.1 Retirement, migration, archiving and destruction

Objective	Entry criteria	Gate / approval	Exit criteria
Remove the system from service without losing required records, meaning, traceability, access control, continuity or legal/regulatory obligations.	Approved retirement decision and named owners for retained data, records and target systems/archives.	System Owner, Data Owner/DRP and QA as applicable; plan approved before execution and report/final closeout after execution.	System deactivated, data/records verified and retrievable, obligations transferred, access/interfaces removed and retirement report approved.

Mandatory activities

172. Approve a retirement plan before execution describing reason, scope, as-is/to-be state, risk, stakeholders, interfaces, data/records, migration/archive/destruction, fallback, schedule, evidence and approval framework.
173. Perform baseline user and periodic-system evaluations before disruptive execution, then perform final closeout assessments covering the period through shutdown; this resolves the temporal ambiguity in older guidance.
174. Identify complete records, metadata, audit trails, signatures, attachments, context and dynamic functionality needed for retention, inspection and business use. Assign enduring Data Owner/archive custodian and retrieval responsibilities.
175. For migration or true-copy transfer, use controlled tools and verify population completeness, accuracy, meaning, chain of custody, reconciliation, exceptions, access and readability. Do not flatten signed records if signature context would be lost.
176. Test archive retrieval, human readability, electronic usability and integrity for the full retention period; define technology-obsolescence monitoring and periodic retrieval checks.
177. Before source deletion or destruction, verify approved retention schedule, transfer completion, legal-hold status, segregation of duties and documented authorisation. Retain signed destruction evidence and population/rationale.
178. Communicate and remove interfaces, scheduled jobs, accounts, secrets, remote access, integrations, licences, monitoring and supplier access; update asset/system-of-record lifecycle status.
179. Maintain the system under control until execution is complete; approve the retirement report with deviations, reconciliation, residual risks, obligations and explicit closure conclusion.

Minimum evidence and approval

Evidence object	Minimum acceptance criteria	Accountable custodian / approval
Approved retirement plan	Scope/risk, data disposition, interfaces, fallback, schedule, roles and criteria	Owner + Data Owner + QA
Data/record inventory and mapping	Complete record definition, retention/legal hold, source-target/archive mapping and custodian	Data Owner
Migration/archive verification	Counts/control totals, sampling rationale, metadata/AT/signatures, retrieval and exceptions	Data Owner + reviewer/QA
Access/interface/dependency closure	Removal evidence, consumer communication, ITOM/asset update, supplier/licence termination	System Manager
Destruction evidence	Authorised population, rationale, legal-hold check, SoD, date/signature and immutable log	Archive/records roles
Retirement report	Execution vs plan, deviations, final PSE/URR, residual obligations and closure	Owner + QA

Difficult-auditor probes

180. Retrieve a randomly selected archived record with metadata, audit trail and signature meaning using only retained procedures and current staff—not the retired application team.
181. Prove the legal-hold and true-copy transfer checks were complete before source deletion; reconcile the destruction list to the approved population.
182. Which consumers, service accounts or scheduled integrations continued after shutdown, and how was the population of hidden dependencies proven complete?

NO-GO CONDITION

No deactivation, source deletion or destruction until approved retention/legal-hold decisions, verified transfer/retrieval, ownership transfer, interface/access closure and fallback criteria are met.

Internal and external basis: Q187219 §4.12; Q0699567; Q153763; Q204010 status caveat; EU GMP Annex 11 §§4.8 and 17; 21 CFR 11.10(b)–(c); 21 CFR 211.180(c).

10 Cross-lifecycle control requirements

The following control planes apply across phases. Tailoring must be explicit in the applicability/risk record; absence of a phase-specific paragraph does not remove an applicable cross-lifecycle obligation.

10.1 Governance, independence and approvals

- 183. The System Owner remains accountable for lifecycle compliance, intended-use fitness, criticality and residual-risk decisions even when work is delegated.
- 184. Delegations and role-equivalence mappings must be documented, competent and within source restrictions. Supplier personnel cannot receive non-delegable ownership accountability.
- 185. QA must be independent of delivery for approval and release decisions. The project must identify the governing approval matrix and resolve the IT-versus-equipment role taxonomy before execution.
- 186. Recorded acceptance/signature must show signer, date/time, meaning and approved version. Workflow routing or attendance is not approval evidence.

Minimum evidence: Role register; delegation records; RACI; training/competence; approval matrix decision; signature audit trail; conflict-of-interest/independence record.

10.2 Documentation, records and evidence integrity

- 187. Use approved templates and controlled repositories appropriate to record criticality; preserve revision history, review comments/decisions and prior approved versions.
- 188. Records must be attributable, legible, contemporaneous, original or verified true copy, accurate, complete, consistent, enduring and available throughout retention.
- 189. Native dynamic evidence, logs, attachments and metadata should be retained when static screenshots cannot preserve meaning or completeness. Evidence references must resolve without personal drives or expiring links.
- 190. Define author, reviewer, approver, custodian, retention, access and periodic currency review for each lifecycle document. A named tool or repository does not itself prove control.

Minimum evidence: Controlled document index; repository access/version audit; native evidence manifest; retention mapping; true-copy verification; overdue-review monitoring.

10.3 Data integrity, audit trails and electronic signatures

- 191. Classify primary/secondary data and define the complete record, including metadata, audit trails, signatures, calculations, interfaces, attachments and contextual records.
- 192. Validate/verify controls for creation, modification, deletion, review, retention, accurate copies and reconstruction. System audit trails must be secure, time-stamped, intelligible and reviewed at risk-defined frequency.
- 193. Audit-trail scope and local instructions must address routine release review, periodic review and investigation. Explicitly map admin, platform and direct-database actions to protected logs and independent review.
- 194. Electronic signatures must remain uniquely attributable, show signer/date-time/meaning and remain permanently linked to the signed record. Shared IDs require exceptional justification and compensating attribution controls.

Minimum evidence: Data classification; data-flow/record map; DI risk controls; ATR assessment/instruction/results; admin/DB log review; signature validation; accurate-copy demonstration.

10.4 Identity, access and segregation of duties

- 195. Authorise access before provision, use unique identities, apply least privilege and role-based access, and separate request, approval, implementation and review for high-risk/privileged access.
- 196. Own and inventory service, machine, test, local, database, OS, emergency and supplier accounts; rotate/secure secrets and remove defaults.
- 197. Revoke access promptly on role/need change and review production access at least annually, more frequently where risk requires. Reconcile authorised and actual populations across all layers.
- 198. Investigate rejected privileged access and actions since the prior review; escalate critical findings to QA, incident/security and deviation processes as applicable.

Minimum evidence: Access request/approval; provisioning logs; role catalogue; SoD analysis; privileged-session logs; complete annual reconciliation; revocation evidence; exceptions.

10.5 Information security and privacy

- 199. Scope all components, environments, suppliers and interfaces in the information-security risk assessment and document shared responsibility for platforms/cloud services.
- 200. Implement mandatory controls or approved exceptions with compensating controls and evidence; only implemented/effective controls may reduce residual risk.

201. Classify data and address privacy by design, purpose limitation, minimisation, lawful basis, retention, data-subject/transfer requirements and supplier/subprocessor controls where personal data applies.
202. Manage vulnerabilities and patches through risk-based triage, test, approval, deployment, exception expiry and effectiveness monitoring; preserve evidence of unsupported-component decisions.

Minimum evidence: Security/privacy assessments; control-evidence matrix; exceptions; architecture/threat model; vulnerability/patch records; DPA/TIA/SCC where applicable; incident linkage.

10.6 Interfaces and data exchange

203. Assign permanent ownership, register every interface and consumer, and maintain technical/service terms, data contracts, security, monitoring and support responsibilities.
204. Verify end-to-end function, accuracy, completeness, transformations, schema/contract, authentication/authorisation, error handling, replay/duplicate prevention, performance and recovery.
205. Control interface changes and version/retirement schedules with upstream/downstream impact assessment and advance consumer communication.
206. Maintain recoverable configurations and monitoring that detects silent partial failures, delayed data and reconciliation discrepancies.

Minimum evidence: Interface inventory/owner; data contract; source-target mapping; end-to-end test; monitoring/reconciliation; change/consumer notices; recovery plan.

10.7 Backup, recovery and business continuity

207. Define business MTD and technology RTO plus RPO and work-recovery time using unambiguous units and scope; document supplier responsibility and data/location protections.
208. Specify what is backed up, method/frequency, retention, separation, encryption/access, monitoring, failure response and post-recovery verification.
209. Verify backup and recovery initially, after significant change and at a risk-defined operational frequency. Recovery exercises must prove data integrity and the approved RPO/RTO/WRT/MTD, not merely technical restore completion.
210. Document manual/alternative continuity arrangements, activation time, trained roles, communications, interface reconciliation and return-to-normal testing.

Minimum evidence: Approved recovery/BCP; backup config/logs; monitored failures; restore exercise with timings/control totals; data-integrity check; action/effectiveness records.

10.8 Training and competence

211. Define competence for each author, approver, tester, reviewer, administrator, user and audit presenter. Complete required training before the task or document an approved, role-specific exception.
212. Training must cover system use and applicable procedures, data integrity, security/privacy, electronic signatures, incident/escalation and inspection conduct.
213. For high-risk testing and review, document independence and technical/process competence; attendance alone is not proof of effective qualification.

Minimum evidence: Role curriculum; training completion; competence assessment; supplier qualification; independence declaration; controlled exception and expiry.

10.9 Inspection and audit readiness

214. Maintain an evidence index that maps each control assertion to the current approved document and objective execution evidence; periodically test retrieval and presenter readiness.
215. Provide accurate, complete and direct answers; correct discovered errors promptly. Communication coaching must never suppress material facts or override honesty.
216. Use current approved PDF/controlled views, knowledgeable presenters, read-only inspector access where appropriate, and a logged request/response process.
217. Trend inspection observations and audit gaps through CAPA and management review. Missing evidence requires a documented rationale and formal impact/deviation assessment where appropriate.

Minimum evidence: Inspection binder/index; retrieval drill; access demonstration; request log; presenter/QA readiness; finding/CAPA trend and effectiveness.

10.10 Conditional AI/ML overlay

218. When AI/ML affects regulated decisions or records, define intended use, prohibited use, human oversight, model/version, input/output handling and the final accountable decision maker.
219. Control data provenance, representativeness, labelling, privacy, prompt/configuration, model/knowledge-base version and evaluation datasets. Prevent training on confidential or regulated data without authorisation.

- 220. Predefine performance, robustness, bias, safety, hallucination/grounding and abstention criteria; retain reproducible results and challenging cases.
- 221. Monitor drift and failure modes; define thresholds for incident, retraining, revalidation/change control, rollback or suspension. Adaptive behaviour must not bypass approved change control.
- 222. These controls close an identified gap in the reviewed corpus for the hackathon. They require formal applicability and source confirmation before any production NN use.

Minimum evidence: AI intended-use/risk assessment; data/model cards; evaluation protocol/results; prompt/model/config baseline; human-review logs; drift/incident/change/rollback evidence.

11 Hackathon audit-readiness test protocol

11.1 Safe test-data boundary

- 223. Use a fictitious system, organisation units, suppliers, people, tickets, batches, records and dates. Prefix every file and page with 'SYNTHETIC – HACKATHON TEST ONLY'.
- 224. Do not ingest production exports, personal data, patient/clinical data, employee records, credentials, secrets, supplier-confidential reports, actual inspection correspondence or live GxP records.
- 225. Where realism requires a controlled-document excerpt, use only authorised copies in the approved workspace and preserve its controlled-status warning; do not imply the hackathon copy is current.
- 226. Separate generated evidence from controlled QMS repositories. Prevent automated write-back, approval, ticket creation, release or messaging from the audit agent.
- 227. At event close, inventory and dispose/archive the synthetic corpus according to the event plan and verify no restricted data were introduced.

11.2 Synthetic system dossier

Field	Synthetic value	Purpose
System	ASTER-RX	Fictitious configured SaaS used to review manufacturing exception records; no real records
Classification	GxP-relevant / business-critical simulation	Drives QA, DI, Part 11 and continuity challenge evidence without asserting a real classification
Scope	Application, IdP, integration API, reporting warehouse, supplier admin and backup/restore service	Creates deliberate component and shared-responsibility complexity
Lifecycle event	Major configuration release plus partial data migration	Exercises Analyse/Implement/Operate evidence and release chronology
Retirement subscenario	Legacy archive and legal-hold conflict	Exercises record completeness, dynamic signature and destruction controls

11.3 Minimum evidence-pack structure

Folder	Required synthetic content
00_Control	Read-me, synthetic-data attestation, source register, dossier index, event approvals
01_Analyse	Concept, role/RACI, applicability/ITRA, functional risk, URS, supplier assessment/agreement
02_Implement	Plan, design/configuration, design review, CM/baselines, IV/OV/PfV, deviations, TRM, release/O&M/handover
03_Operate	Users/access, ATR, monitoring, backup/recovery, supplier, changes, incidents/problems/CAPA, PSE
04_Retire	Retirement plan, inventory, migration/archive/destruction, retrieval evidence, closeout report
05_Audit	Question log, agent responses, source citations, contradiction/unknown register, scoring and human adjudication

Recommended filename pattern: SYSID_PHASE_DOCTYPE_SEQUENCE_VERSION_STATUS_YYYYMMDD.ext. Each evidence object should carry a unique ID, synthetic label, system/environment/version, author/reviewer/approver, status, date/time zone, source references and linked risks/requirements/changes/deviations.

11.4 Audit-agent answer contract

- 228. Restate the control question and applicable system/time/version boundary.
- 229. Give the conclusion using one of: Demonstrated; Partially demonstrated; Not demonstrated; Not applicable with evidence; Unable to determine.
- 230. Cite the exact evidence object, section/page or record field and the governing source/section. Separate source requirements from inferences.
- 231. List contradictions, stale/unapproved sources, missing populations, chronology/version mismatches and alternative explanations.
- 232. State confidence (High/Medium/Low) and why. High confidence requires corroborating execution evidence, not only an approved narrative.
- 233. Identify the human role required to adjudicate or approve; never fabricate, auto-close or infer compliance from absence of a record.

11.5 Scoring rubric

Score	Meaning	Audit standard
0	Absent / contradicted	No evidence, wrong system/version, or evidence directly contradicts the control

Score	Meaning	Audit standard
1	Claim only	Narrative assertion, interview answer or checklist mark with no objective evidence
2	Document located	Relevant artefact exists but is stale, draft, incomplete, unapproved, weakly traceable or unsupported by execution
3	Demonstrated	Current approved requirement/process plus traceable execution evidence meeting predefined criteria
4	Corroborated / resilient	Level 3 plus independent approval/review, cross-record consistency, population reconciliation and tested effectiveness

Finding threshold

Any Critical Aspect, data-integrity, security/privacy, release, legal-hold or source-currency question scored 0–1 is an immediate human escalation. Scores are diagnostic; they are not regulatory compliance certifications.

11.6 Bias and adversarial checks

Bias	Failure mode	Required countermeasure
Confirmation bias	Agent retrieves only documents supporting the expected conclusion	Require disconfirming search and contradiction register
Recency/status bias	Newest filename or SharePoint modified date treated as effective	Use controlled status/effective metadata and supersession
Authority bias	Signed or supplier-branded evidence accepted without scope/integrity test	Apply evidence acceptance test and supplier suitability
Coverage illusion	Many documents mistaken for complete requirement coverage	Bidirectional traceability and population reconciliation
Automation bias	Confident generated answer accepted without exact source	Mandatory citations, confidence, abstention and human adjudication
Severity dilution	Numeric risk score masks high patient/product/data impact	Review severity, uncertainty and Critical Aspects separately

12 Deviations, exceptions and change to this test artefact

234. Record any departure from this hackathon protocol with ID, requirement, reason, risk/impact, proposed alternative, owner, due date, approval and closure evidence.
235. A hackathon deviation cannot waive an applicable regulation or current controlled NN requirement. Escalate to the appropriate accountable/QA role for interpretation.
236. Version this synthetic SOP when content changes; preserve the previous version and a change summary. Re-run source-currency and scenario-impact checks before event use.
237. Record and adjudicate false positives, false negatives, unsupported inferences, retrieval failures, citation errors and security/privacy boundary breaches as test incidents.
238. If restricted or real regulated data are discovered, stop ingestion/use, preserve necessary evidence, restrict access and follow authorised security/privacy/quality escalation.

ID	Source	Description	Impact	Action	Decision
DEV-####	Requirement / scenario	Observed departure and time	GxP/DI/security/privacy/test-validity impact	Action / owner / due	Approval / closure
[Example] DEV-001	Challenge 18 chronology	Synthetic timezone offset created false release gap	Test validity only; no real system	Correct timestamps; retain before/after; scenario owner	Hackathon QA adjudicator

13 Records, retention and metrics

13.1 Required event records

Record	Custodian	Retention rule
Approved event charter and synthetic-data boundary	Event owner	Per approved event record plan
Source register and controlled-status checks	Content lead / QA adjudicator	Through event review and lessons learned
Synthetic evidence pack and manifest	Scenario owner	Per event plan; segregated from production QMS
Question/answer/citation/contradiction logs	Audit-agent test lead	Per event plan; retain reproducibility metadata
Scores, human adjudication and defects	Audit lead	Through remediation/effectiveness review
Data-disposal or authorised archive confirmation	Event owner / security/privacy	Evidence of event closure

13.2 Minimum metrics

Metric	Definition	Suggested hackathon target
Grounded answer rate	% conclusions with resolvable evidence and source citations	≥95% for final demo set
Unsupported assertion rate	% material claims with no evidence	0% for Critical Aspect/release/DI conclusions
Contradiction detection	% seeded contradictions correctly surfaced	100% critical; ≥90% overall
Stale-source detection	% seeded draft/training/superseded copies flagged	100%
False positive / false negative	Human-adjudicated control/finding errors	Trend by severity; no unresolved critical error
Evidence retrieval time	Median and 95th percentile to exact cited location	Event-specific baseline; improve without lowering accuracy
Abstention quality	% insufficient-evidence cases correctly marked unable/not demonstrated	≥95%
Data-boundary compliance	Restricted-data or write-back events	0

14 Worked examples

14.1 Example A – Major configured SaaS release

Step	Expected control response
Trigger	Supplier changes a rules engine and data export API used by a simulated GxP review workflow.
Analyse	Confirm intended-use impact, component/interface scope, supplier notification duty, ITRA/functional risk and Critical Aspect requirements.
Implement	Update configuration/design and TRM; baseline tenant; verify boundaries, negative cases, audit trail, export accuracy and end-to-end user workflow; manage failures as deviations.
Release	Reconcile release version, traceability, changes/deviations, O&M/monitoring, recovery and access; Owner fitness plus QA release before first production-like event.
Operate	Monitor export reconciliation and supplier KPIs; review privileged supplier actions and include release in PSE.
Difficult probe	The supplier release note says v8.4, production UI says v8.4.1, and test evidence says v8.3. The correct outcome is 'not demonstrated' until version equivalence and impact are resolved.

14.2 Example B – Retirement with archive and legal hold

Step	Expected control response
Trigger	Legacy system replacement is complete, but records contain electronic signatures and a subset may be under legal hold.
Plan	Define complete records, metadata/AT/signature/dynamic functions, retention/legal hold, source-target/archive population, owners, retrieval criteria, fallback and destruction conditions.
Verify	Reconcile all records and control totals, sample by risk, retrieve with signature meaning and audit history, and test archive access using staff independent of the migration.
Close	Remove interfaces/accounts/licences, update system lifecycle, approve retirement report, and destroy only the authorised non-held population with SoD and signed evidence.
Difficult probe	A PDF view is readable, but signatures were flattened and audit-trail context is absent. Readability alone does not demonstrate a complete retained record.

15 Auditor challenge pack

Seed the scenarios below across documents and execution evidence. The difficult auditor should triangulate system ID, component scope, version, timestamps, named roles, record populations and source status across independent records; cross-record discrepancies are often more probative than a missing document in isolation.

#	Challenge	Injected fact pattern	Expected evidence	High-risk red flag
01	Source currency	A copied procedure is newer by filename but still marked Issued/Training Copy with a proposed effective date.	Live QMS metadata, effective/superseded state, applicability decision and approved source register.	Treating SharePoint modified date or proposed date as effective status.
02	Non-delegable ownership	Risk acceptance was clicked by a project manager using an Owner-routed workflow.	Named Owner mandate, recorded acceptance/signature and delegation restriction.	Workflow completion with no Owner acceptance evidence.
03	Conflicting approval matrices	IV/OV has one manager approval under the IT procedure but a generic validation guide shows two approvers.	Documented system classification, governing procedure, role cross-map and QA concurrence.	Choosing the lighter matrix after execution.
04	Scope reconciliation	The risk assessment lists one interface; architecture and ITOM show four.	Component/interface population reconciliation and updated risk/verification.	Unassessed environments, APIs or platform dependencies.
05	Skipped QA	IRM workflow records 'Skip QA Acceptance' for a GxP solution.	Applicable instruction, rationale, independent QA review and corrected released risk record.	Assuming a system option creates permission.
06	Supplier before contract	Vendor engineers accessed the tenant before assessment and agreement approval.	Access logs, procurement timeline, approved assessment/agreement and impact/deviation.	Backdated or retroactive evidence with no impact assessment.
07	SOC reliance	A clean SOC cover page is filed, but the service uses a carved-out subprocessor and several CUECs.	Full report analysis, scope/period mapping, exceptions, CUECs, gap bridge and owner evidence.	Certificate receipt without control implementation proof.
08	SaaS push release	Supplier deployed a backend change before customer testing.	Notification, release-note triage, tenant impact, verification/monitoring and acceptance.	No link between supplier version and production evidence.
09	URS orphan	A critical audit-trail requirement has no design or test reference.	Bidirectional traceability, justified verification method and closed gap.	Counting document presence instead of requirement coverage.
10	Design sampling bias	Final design review spot-checked 10 of 300 elements and concluded all were fit.	Population, sampling rationale, all Critical Aspects, findings and closure.	Unrepresentative sample with no CA reconciliation.
11	Unreviewed custom code	Critical custom calculation had no independent code review.	Risk, standards, reviewer independence, design trace and approved exception if any.	Developer self-approval or retrospective review only.
12	Baseline mismatch	Production configuration differs from release baseline.	Configuration diff, authorised change IDs, risk/test and revised baseline.	Manual 'as built' spreadsheet with unexplained values.
13	Bare OK evidence	High-risk verification steps contain only 'OK'.	Expected/actual values, native objective evidence, tester/date/context and review.	Status label used as sole basis for acceptance.
14	Reused supplier test	FAT evidence is reused after transport, tenant configuration and a version update.	Suitability/equivalence, integrity, exact versions, change impact and supplemental test.	Assuming vendor pass transfers automatically.
15	Defect vs deviation	A failed formal acceptance step was closed as a software defect only.	Validation-deviation classification, impact, retest/regression and closure approval.	No assessment of protocol/validated-state impact.
16	Criterion moved	Acceptance limit changed after the first failure.	Original result, deviation, scientific rationale, QA agreement, reapproved protocol and retest.	Edited script with overwritten history.
17	Migration reconciliation	Only a small convenience sample was checked after migration.	Population counts/control totals, stratified/risk sample, metadata/AT/signature checks and exceptions.	No completeness proof or sample rationale.
18	Release chronology	First production event predates QA release by two hours.	System timestamps, release/signature audit, access, deployment and incident/deviation assessment.	Timezone explanation with no source evidence.
19	Handover gap	Checklist rows were deleted and missing evidence put on an unsigned action plan.	Template change rationale, accountable acceptance, risk/no-go assessment and closure.	Using checklist completion as release approval.
20	Privileged population	Annual review covers application users but not DB, OS or service accounts.	Authorised-vs-actual reconciliation across layers and activity review for rejected privileges.	Central directory export assumed complete.
21	Audit-trail handoff	ATR excludes direct DB/admin activity; IRM control says logging is enabled but no review exists.	Protected logs, owner, frequency, independent review, issue handling and effectiveness.	Control design claim without execution evidence.
22	Recovery objective	Restore succeeded, but business recovery exceeded RTO and data exceeded RPO.	Timed recovery report, control totals, root cause/CAPA, risk and BCP update.	Calling technical restore a successful recovery test.
23	Recurring lower incidents	Seven P2 events never triggered a problem record.	Trend thresholds, aggregate impact, problem/CAPA decision and rationale.	Limiting systemic analysis to single P1/Major events.
24	Late PSE	PSE exceeded the stated 60-day completion target using an informal extension.	Applicable rule, approved exception/deviation, impact, action and final validated-state conclusion.	Email extension with no QMS control.
25	Archive/destruction	Source data were deleted after true-copy transfer while a legal hold and dynamic signature context were uncertain.	Complete-record mapping, legal-hold check, verified transfer/retrieval, SoD and signed destruction population.	Assuming audit trail alone can reconstruct the record.

16 Confidence, limitations and known control gaps

Confidence	Area	Basis / limitation
High	Lifecycle structure and principal NN IT controls	Attached Q187219 v12.0 plus current effective Q0307516/Q187218 and multiple corroborating sources were fully read.
High	External regulatory clause mapping	Official eCFR, European Commission, ICH, FDA, PIC/S and MHRA sources were checked; clause ranges are listed in Section 17.
Medium	Cross-document synthesis and approval resolution	Reasoned reconciliation of different scopes/role taxonomies; must be confirmed for each live system by QA.
Medium	Guidance/template implementation details	Many supplied items are Approved guidance/templates rather than Effective instructions and some are older.
Low until verified	Q204010, Q0301870 and Q216301 as governing sources	Supplied copies were marked Issued/Training Copy with proposed effective dates; live QualityDocs status is required.
Deliberate extension	AI/ML and software-supply-chain controls	Added to close corpus gaps for a demanding hackathon; not asserted as explicit requirements of every supplied NN procedure.

239. The reviewed corpus does not provide a complete AI/ML lifecycle (training/data provenance, bias/robustness, drift, retraining thresholds and adaptive change). Section 10.10 is a conditional hackathon strengthening overlay.

240. CM and TRM guidance do not name mandatory approvers or formal baseline/completeness metrics. This SOP assigns project-specific RACI, baseline and reconciliation expectations.

241. Supplier-evidence suitability lacks a single minimum checklist across sources. This SOP requires scope/version/environment, raw/native evidence, integrity, competence, deviations and retention review.

242. Cloud/SaaS, DevSecOps and software-supply-chain controls are distributed rather than end-to-end. The draft consolidates shared responsibility, release acceptance, dependencies, provenance and scanning on a risk basis.

243. Several guidance documents use legacy tools/terminology. A named tool does not prove qualification, current configuration, access, interfaces or retention.

244. The attached PDF is an uncontrolled printed copy after its print date. No conclusion in this document proves the live controlled version on 23 August 2026.

GAMP 5 limitation

The synthesis is conceptually aligned with a risk-based lifecycle, but no exact GAMP 5 clause mapping is asserted because a licensed controlled copy was not supplied. Verify any GAMP citation against the organisation's licensed second-edition guide before use.

17 References and source register

17.1 Official external sources

External requirements apply only when the system, process, record and jurisdiction are in scope. The cited text is not reproduced here; use the official source and applicable effective date for interpretation.

Source	Exact sections used	Control themes	Official link
21 CFR Part 11	§§11.1; 11.10(a)–(k); 11.30; 11.50; 11.70; 11.100; 11.200; 11.300	Scope; validated/controlled records; accurate copies/retention; access/audit trails; signatures; identity controls	Open source
21 CFR Part 211	§§211.25; 211.68; 211.100; 211.180(c)–(e); 211.192	Training; computer-system checks/accuracy/backup; written procedures; retrieval/review; discrepancy investigations	Open source
EU GMP Annex 11	Principle and §§1–17; especially 3–4, 7, 9–13, 16–17	Application validation/infrastructure qualification; lifecycle risk; suppliers; URS/traceability; operation; continuity; archiving	Open source
EU GMP Annex 15	§§1.1–1.8; 2.1–2.10; 3.1–3.14; 4.1–4.2; 11.1–11.7	Planning/quality oversight/data integrity; protocols/deviations/release; URS/DQ/FAT/SAT/IQ/OQ/PQ; requalification; change control	Open source
ICH Q9(R1)	§§3; 4.1–4.6; 5.1–5.3	Scientific and proportionate quality risk management; assessment/control/communication/review; subjectivity and formality	Open source
FDA Data Integrity Guidance	Questions and Answers 1–18 (December 2018)	Data integrity governance, metadata, audit trails, access, review, invalidated testing and investigations; nonbinding guidance	Open source
PIC/S PI 041-1	Sections 5–12 and appendices, as applicable	Data governance, lifecycle, computerised-system controls, audit trails and inspection expectations	Open source
MHRA GxP Data Integrity Guidance	Definitions and organisational/technical control sections	ALCOA+ expectations, data lifecycle, governance and risk-based controls	Open source
ISPE GAMP 5, 2nd edition	No clause mapping asserted in this draft	Conceptual lifecycle/risk-based alignment only; use a licensed controlled copy for exact section mapping	Open source

Appendix A – Phase deliverable and approval matrix

#	Macro	Lifecycle stage	Minimum exit deliverable	Gate / approval
1	ANALYSE	Concept, intended use and business case	Approved concept package, appointed roles, system boundary/data flow, and initial applicability decision.	System Owner accountable; Business Process Owner concurs with intended use; QA confirms GxP applicability where relevant.
2	ANALYSE	User requirements specification (URS)	Approved, uniquely identified and baselined URS with classifications and traceability initiated.	System/Project Owner and QA for GxP under the IT-specific framework; approved final URS before formal final design review.
3	ANALYSE	Risk assessment, criticality and software categorisation	Released ITRA/applicability assessment, functional risk assessment and justified validation/verification strategy.	System Owner accepts criticality and residual risk; this acceptance is not delegated. QA reviews/approves GxP scope and risks as required.
4	ANALYSE	Supplier and service-provider assessment	Approved supplier assessment and agreement before delivery, regulated-data access or reliance on supplier evidence.	System Owner/Manager, Sourcing and QA as applicable; Owner approves evaluation-method rationale and residual risk; agreements follow procurement/legal authority.
5	IMPLEMENT	Functional and design specification	Approved design baseline and final design-review conclusion before acceptance verification.	As defined in the approved plan; formal final design review by System/Project Manager and QA for applicable GxP IT systems.
6	IMPLEMENT	Configuration, development and configuration management	Verified build/configuration, controlled code and artefacts, approved pre-verification baseline and complete configuration record.	Approvers and independence defined in the plan; independent review for development verification; baseline acceptance assigned in RACI.
7	IMPLEMENT	Installation verification / qualification	Approved IV/IQ report, reconciled component/configuration baseline and all material deviations closed.	IT-specific IV plan/report: System/Project Manager; apply the documented alternative matrix if the scope is equipment/infrastructure or mixed.
8	IMPLEMENT	Operational verification / qualification	Approved OV/OQ report with objective evidence, traceability and closed material deviations.	IT-specific OV plan/report: System/Project Manager; alternative two-approver framework applies only when documented as governing.
9	IMPLEMENT	Performance verification / qualification and user acceptance	Approved PfV/PQ/UAT report, business acceptance and proven migration/cutover readiness where applicable.	System/Project Manager and QA when Critical Aspects are affected under the IT matrix; follow the documented governing framework.
10	IMPLEMENT	Release, go-live and operational handover	Signed release, approved validation/implementation report, accepted O&M handover and communicated production status.	System/Project Manager and QA for applicable release; System Owner concludes fitness and approves validation report; QA grants final GxP release.
11	OPERATE	Operation, monitoring and periodic evaluation	Continuous operation with current evidence, timely reviews/actions and an explicit state-of-control conclusion.	System Owner accountable; System Manager executes; QA reviews/approves GxP O&M and applicable PSE/validated-state conclusions.
12	OPERATE	Change and configuration management	Implemented change linked to updated risk/specification/verification/configuration evidence and effectiveness conclusion.	Change Manager/System Manager, System Owner, QA and business/technical roles according to impact and governing QMS workflow.
13	OPERATE	Incident, problem and validation-deviation management	Service restored safely, impact concluded, deviations/CAPA closed or controlled, recurrence risk reviewed and validated state addressed.	Incident/problem roles and System Manager; QA for GxP assessment and validation-deviation closure per classification; accountable Owner accepts residual risk.
14	RETIRE	Retirement, migration, archiving and destruction	System deactivated, data/records verified and retrievable, obligations transferred, access/interfaces removed and retirement report approved.	System Owner, Data Owner/DRP and QA as applicable; plan approved before execution and report/final closeout after execution.

Matrix note: approvals are a synthesis for the hackathon. The live applicable procedure, documented system classification and approved project plan determine the legally/QMS effective approvers. Conditional stage progression cannot authorise final production release.

Appendix B – Revision and approval record

Version	Date	Change summary	Author
0.1	23-Aug-2026	Initial synthetic master SOP generated from attached Q187219 v12.0, the supplied 53-item SharePoint corpus and official regulatory sources	Hackathon Working Draft

B.1 Event-use approval

Role	Name	Meaning	Signature / date
Prepared by	Hackathon Content Lead [placeholder]	Drafting	___ / ___ / 2026
Reviewed by	IT Quality / CSV SME [placeholder]	Technical review	___ / ___ / 2026
Reviewed by	Information Security / Privacy [if applicable]	Specialist review	___ / ___ / 2026
Approved for event	Hackathon Sponsor [placeholder]	Use as synthetic test artefact only	___ / ___ / 2026

B.2 Final acceptance checklist

- 245. All placeholders are replaced or deliberately retained as synthetic labels.
- 246. Live controlled status and applicability are verified for every governing internal source.
- 247. No real personal, confidential, patient, batch, clinical or production GxP data are present.
- 248. The evidence manifest, challenge seed map and expected adjudications are independently reviewed.
- 249. The audit agent is read-only, citations resolve, contradictions are preserved and human escalation is tested.
- 250. Word pagination, tables, links, headings and accessibility are visually checked before event distribution.